דוח מחקר

תקציר ומוטיבציה

מחקר זה בוחן את השפעתם של מנגנוני אחסון סיסמאות ומנגנוני הגנה שונים על עמידות מערכת אימות משתמשים בפני תקיפות Brute force ו- Password spraying. לצורך כך הוקמה סביבת ניסוי מבוקרת במבנה של שרת-לקוח, בה בוצעו תקיפות מדומות ונמדדו מדדים כגון זמן התקיפה, קצב הניסיונות, הצלחת התקיפה, ושימוש במשאבי מעבד וזיכרון. הניסויים בוצעו עבור מנגנונים בודדים וכן עבור שילובים של מספר מנגנוני הגנה, במטרה להשוות את השפעתם על תוצאות התקיפה.

טענת המחקר היא כי שילוב מנגנון אחסון חזק (Argon2) יחד עם מנגנוני ההגנה משלימים מסוג Rate limiting ו-TOTP מפחית את יעילות התקיפות בהשוואה לשימוש במנגנונים בודדים, תוך שינוי מאפייני העומס החישובי והשפעה מוגבלת על תהליך ההזדהות התקני של המשתמש.

מערכות אימות מבוססות סיסמאות מהוות רכיב מרכזי במערכות מידע רבות, ובה בעת יעד נפוץ לתקיפות אוטומטיות. חיזוק מנגנוני האימות עשוי לשפר את רמת האבטחה, אך עלול להשפיע גם על ביצועי המערכת ועל חווית המשתמש. לפיכך, קיים צורך לבחון את רמת האבטחה המרבית שניתן להשיג תוך איזון בין מניעת תקיפות, עומס חישובי והשפעה על תהליך ההתחברות התקני.

רקע

מנגנוני אחסון סיסמאות

מנגנוני אחסון סיסמאות נועדו למנוע שחזור של סיסמאות במקרה של דליפת בסיס הנתונים.

1. SHA256 עם salt – אלגוריתם גיבוב חד כיווני המפיק ערך hash קבוע. שילוב salt אקראי יוצר שונות בין סיסמאות זהות ומקשה על שימוש חוזר ב-hashes זהים.
2. Bcrypt – אלגוריתם גיבוב המשלב salt אקראי וגורם האטה חישובי (cost factor), אשר מגדיל את זמן החישוב לכל ניסיון ובכך מפחית את יעילות תקיפות ניחוש.
3. Argon2 – אלגוריתם גיבוב חד כיווני המבוסס על צריכת זיכרון גבוהה ופרמטרים הניתנים להגדרה, ונועד להקשות על תקיפות מקביליות מקנה מידה רחב.

שיטות תקיפה

1. Brute force - תקיפה על מערכת אימות המבוססת על ניסיונות חוזרים של סיסמאות שונות עבור משתמש יחיד, עד למציאת סיסמה תקפה או חסימת ההתקפה.
2. Password spraying – תקיפה שעושה שימוש במספר מועט של סיסמאות נפוצות המנוסות על משתמשים רבים, במטרה לעקוף מנגנוני חסימה המבוססים על מספר ניסיונות לכל משתמש.

מנגנוני הגנה

1. Pepper – מוסיף ערך סודי גלובלי לתהליך גיבוב הסיסמה, ובכך מגדיל את הקושי בניצול דליפת נתונים.
2. Account locking – חוסם את חשבון המשתמש לאחר מספר ניסיונות כושלים.
3. Rate limiting – חוסם זמנית את ההתחברות לחשבון המשתמש לאחר מספר ניסיונות כושלים, בכך מגביל את קצב ניסיונות ההתחברות בזמן נתון.
4. TOTP - מוסיף שלב אימות מבוסס זמן וסוד לאחר הזנת סיסמה תקפה.
5. Captcha - נועד להבחין בין משתמש אנושי לתוקף אוטומטי על ידי הוספת אימות אנושי.

תצורה ניסויית

כל הניסויים בוצעו במחשב נייד יחיד הפועל תחת מערכת הפעלה Windows. סביבת הפיתוח וההרצה התבססה על Python בסביבת virtual environment (venv), תוך שימוש ב- GitHub לניהול גרסאות.

המערכת הורכבה משרת אימות ולקוח תקיפה שתקשרו ביניהם באמצעות בקשות HTTP דרך ממשק REST. השרת סיפק נקודת קצה לאימות משתמשים (\login), בעוד שהתקיפה בוצעה באמצעות בקשות POST לשרת.

שרת האימות מומש באמצעות Flask בשפת Python. נתוני המשתמשים ופרטי האימות אוחסנו במסד נתונים מקומי מסוג SQLite בניהול SQLAlchemy. פרמטרי הניסוי, לרבות תרחיש התקיפה והפעלת מנגנוני ההגנה, הוגדרו באמצעות קובץ קונפיגורציה (config.json) אשר נטען בריצה ומאפשר שינוי תצורות ללא שינוי קוד.

כל ניסיונות האימות תועדו בקובצי לוג בפורמט JSON (login_logs.json), שימשו לניתוח ולהשוואת התוצאות.

מתודולוגיה

סט משתמשים

המחקר בוצע על סט של 30 משתמשים, אשר סווגו לשלוש רמות חוזק סיסמה: חלשה, בינונית וחזקה, כאשר בכל רמה נכללו 10 משתמשים. עבור כל סיסמה נבדקה עמידה בקריטריונים הבאים:

1. אורך סיסמה העולה על 8 תווים.
2. הכללת אותיות קטנות באנגלית (a-z).
3. הכללת אותיות גדולות באנגלית (A-Z).
4. הכללת ספרות (9-0).
5. הכללת תווים מיוחדים.

רמת חוזק הסיסמה הוגדרה בהתאם למספר הקריטריונים שהתקיימו: קריטריון אחד – סיסמה חלשה, שניים עד שלושה קריטריונים – סיסמה בינונית ויותר משלושה קריטריונים – סיסמה חזקה.

תרחישי תקיפה

בוצעו שני תרחישי תקיפה מקוונים באמצעות ממשק REST על שרת האימות, בהתבסס על מילון rockyou.

1. **Brute force** - ניסון התחברות לחשבון יחיד באמצעות מעבר סדרתי על סיסמאות מהמילון. לצורך השוואה נבחרו שישה משתמשים מייצגים, שניים מכל רמת חוזק.
2. **Password spraying** – ניסיון התחברות באמצעות מספר מוגבל של סיסמאות נפוצות עבור כלל 30 המשתמשים, נבדקו 150 הסיסמאות הראשונות מהמילון.

כל ריצת תקיפה הוגבלה ל-50,000 ניסיונות או לזמן ריצה מרבי של שעתיים, המוקדם מבניהם. בכל ריצה הופעל מנגנון אחסון אחד, בחלקם הופעלו מנגנוני הגנה. בתקיפה מוגדר sleep של 0.8 שנייה לכל 100 ניסיונות, למניעת הקרסת השרת.

מנגנוני אחסון

ניסויי המחקר בוצעו תוך שימוש באחד משלושת מנגנוני אחסון הסיסמאות השונים:

1. **Sha256 עם salt** אקראי לכל משתמש
2. **Bcrypt** – עם פרמטר cost קבוע של 12.
3. **Argon2id** – עם פרמטרים time = 1, memory = 64MB, parallelism = 1.

<u>מנגנוני הגנה</u>

חלק ניסויי המחקר בוצעו בשימוש חלק ממנגנוני ההגנה:

1. **Pepper** – שימוש במחרוזת קבועה (GROUP SEED = 14320970).
2. **Account locking** - נעילת חשבון לאחר כל 10 ניסיונות כושלים.
3. **Rate limiting** – הגבלת קצב ניסיונות ההתחברות באמצעות השהיה ל5 שניות לאחר כל 10 ניסיונות.
4. **TOTP** - אימות דו-שלבי באמצעות קוד חד-פעמי מבוסס זמן, הנדרש לאחר הזנת סיסמה תקפה. הסוד מוגדר לחלק מהמשתמשים בקובץ הקונפיגורציה.
5. **Captcha** - הפעלת המנגנון לאחר כל 10 ניסיונות כושלים הכולל השהייה של שנייה בהימצאות אסימון, והשהייה של 5 שניות בהיעדר אסימון.

<u>מדדים שנמדדו</u>

בכל ניסוי נאספו המדדים הבאים:

1. **מספר הניסיון בו התקיפה נעצרה** – עקב הצלחה, הגעה למגבלת ניסיונות או חלוף זמן מרבי.
2. **זמן התקיפה הכולל.**
3. **קצב ניסיונות לשנייה** – מחושב כיחס בין מספר הניסיונות למשך זמן התקיפה.
4. **צריכת המעבד של השרת**– נמדדה כחציון הדגימות שנאספו בדגימה מחזורית כל חצי שנייה.
5. **שימוש בזיכרון של השרת** - נמדד כערך שיא בMB של זיכרון השרת במהלך התקיפה.
6. **זמן השהיה (Latency)** – משך הזמן במילישניות בין שליחת בקשת התחברות לשרת לבין קבלת התשובה ממוצע זמני ההשהיות חושב לאחר השמטת 10 הניסיונות הראשונים, בשל שלב warm-up בתחילת הריצה.

<u>איסוף לוגים ושחזור הניסוי</u>

כל ניסיונות האימות תועדו בקובץ login_logs.json בפורמט מובנה, הכולל פרטי זמן, משתמש, מנגנון אחסון, זמן ניסיון האימות, מנגנוני הגנה פעילים וזמן השהייה. לוגים אלו שימשו לניתוח מהלך התקיפה ותוצאותיהן.

לצורך הבטחת יכולת שחזור הניסוי, כל הניסויים בוצעו תחת קונפיגורציה קבועה (קובץ config.json). סט המשתמשים, סיווג הסיסמאות, מילון הסיסמאות, מגבלת הזמן ומספר הניסיונות נשמרו אחידים בין כלל הריצות. ההבדלים בין הריצות נבעו ממנגנון אחסון הסיסמאות וממנגנוני ההגנה שהופעלו בכל ניסוי.

ערך ה- GROUP SEED משמש לצורכי זיהוי ועקביות בלבד, ואינו מהווה פרמטר ניסויי.

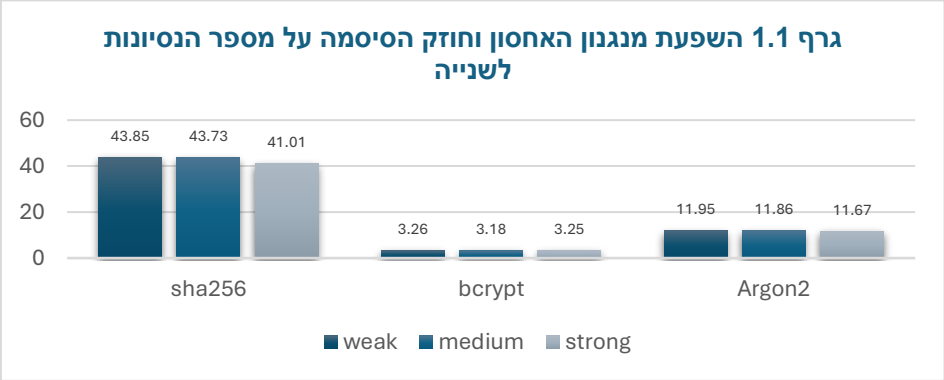
הניסויים בוצעו בסביבה מעבדתית מקומית, ולפיכך, ייתכן כי מאפייני החומרה ותהליכים הפועלים ברקע ישפיעו על הערכים המוחלטים הנמדדים. עם זאת, היחסים והמגמות בין התצורות השונות צפויים להישמר.

תוצאות

תוצאות תקיפה לפי מנגנוני אחסון וללא מנגנוני הגנה

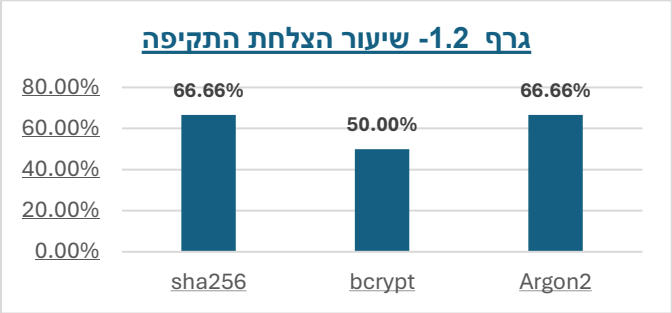
1. **תקיפת Brute force**

א. מספר ניסיונות וזמן עד עצירת התקיפה



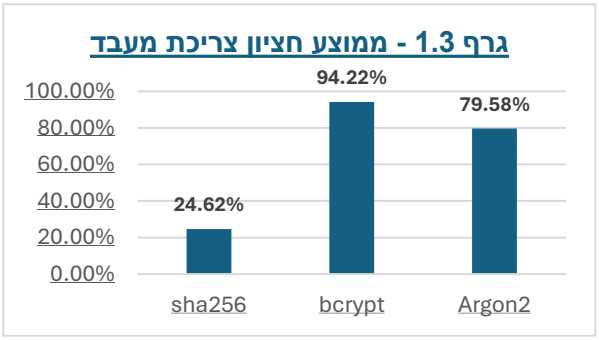
גרף 1.1 מציג את מספר ניסיונות ההתחברות לשנייה עבור מנגנוני האחסון השונים. הגרף מראה פערים ברורים במספר הניסיונות בין מנגנוני האחסון, בעוד שלא נצפתה תלות מובהקת בין מספר הניסיונות לבין חוזק הסיסמה. בנוסף מספר bcrypt הוביל למספר ניסיונות נמוך יותר ולזמני ריצה ארוכים יותר בהשוואה ל-sha256, בעוד ש-Argon2 הציג ערכי ביניים. פירוט הערכים בטבלה 1.1 בנספחים.

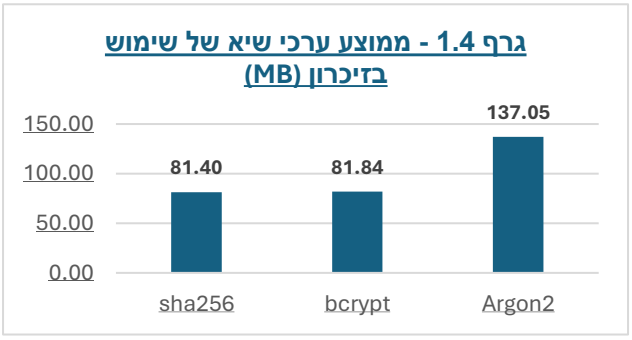
שיעור הצלחת התקיפה



גרף 1.2 מציג את שיעור הצלחת התקיפה עבור מנגנוני האחסון השונים. מן הגרף עולה כי שיעור ההצלחה עמד על 66.66% עבור sha256 ו- Argon2, בעוד ששב-bcrypt נצפה שיעור הצלחה נמוך יותר של 50% הנבע מאי הצלחה של סיסמה בינונית אחת. פירוט תוצאות אלו מוצג בטבלה 1.1.

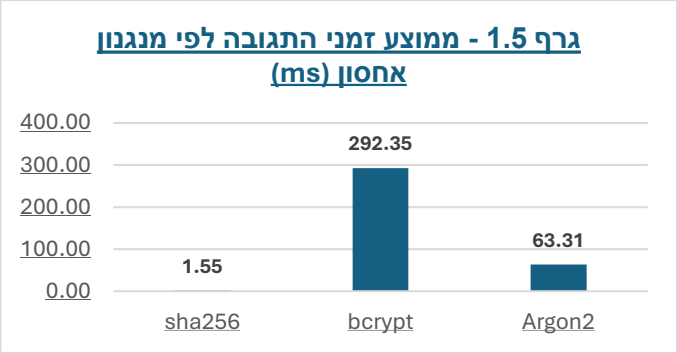
ב. חישוב העומס על השרת





גרף 1.3 מציג את ממוצע של חציוני צריכת המעבד של השרת, במהלך התקיפה עבור מנגנוני האחסון השונים. הגרף מראה כי מנגנון bcrypt הוביל לצריכת מעבד גבוהה יותר בהשוואה לשאר המנגנונים. גרף 1.4 מציג את ממוצע ערכי השיא של שימוש בזיכרון, ומראה כי מנגנון Argon2 הוביל לשימוש גבוה יותר בזיכרון בהשוואה לשאר המנגנונים. פירוט צריכת המעבד והזיכרון עבור כל תצורה בטבלה 1.2.

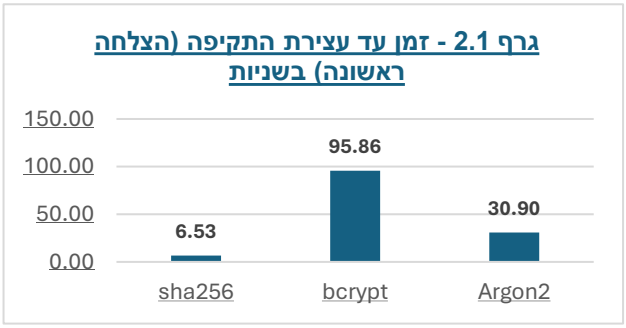
ג. זמני תגובה של השרת



גרף 1.5 מציג את זמני התגובה של השרת במהלך התקיפה עבור מגנוני האחסון השונים. מן הגרף עולה כי זמני התגובה ב-bcrypt היו הגבוהים ביותר, בעוד ש-SHA256 הציג זמני תגובה נמוכים משמעותית ו-Argon2 ערכי ביניים. פירוט ממוצע זמני התגובה לכל תצורה מוצג בטבלה 1.3.

2. Password spraying

א. תוצאות התקיפה

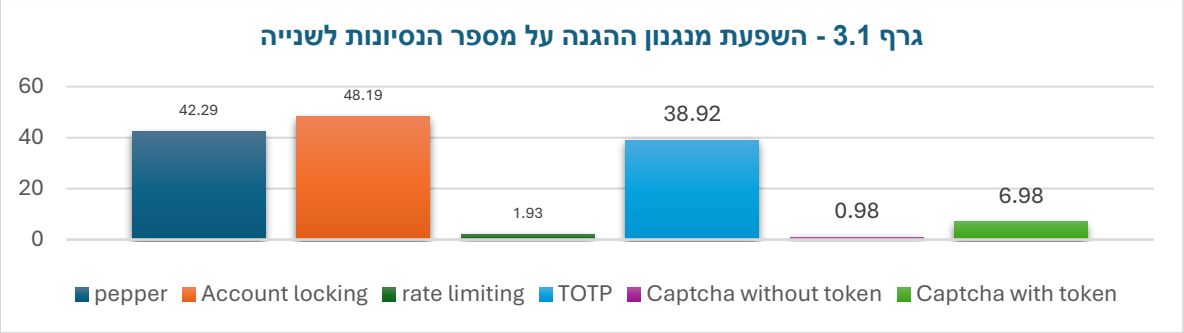


גרף 2.1 מציג את זמן התקיפה עד להצלחה ראשונה, עבור מנגנוני האחסון השונים. בכל התצורות התקיפה הובילה למציאת סיסמה תקפה עבור אותו משתמש (daniel01) ולאחר מספר ניסיונות זהה. ההבדלים באו לידי ביטוי במשך הזמן עד ההצלחה הראשונה. פירוט הנתונים מוצג בטבלאות 2.1 ו-2.2.

3. תוצאות תקיפה Brute force עם מנגנוני הגנה פרטני

מדידת הצלחת התקיפה			
מנגנון הגנה	הצלחת תקיפה	מנגנון הגנה	הצלחת התקיפה
pepper	כן	TOTP	לא
Account locking	לא	Captcha בלי טוקן	כן
rate limiting	כן	captcha עם טוקן	כן

הטבלה מציגה את תוצאות התקיפה עבור מנגנוני הגנה שונים בעת שימוש בSHA256. ממנה עולה כי מנגנוני Account locking ו- TOTP מנעו את הצלחת התקיפה, בעוד שבשאר המנגנונים התקיפה הצליחה.

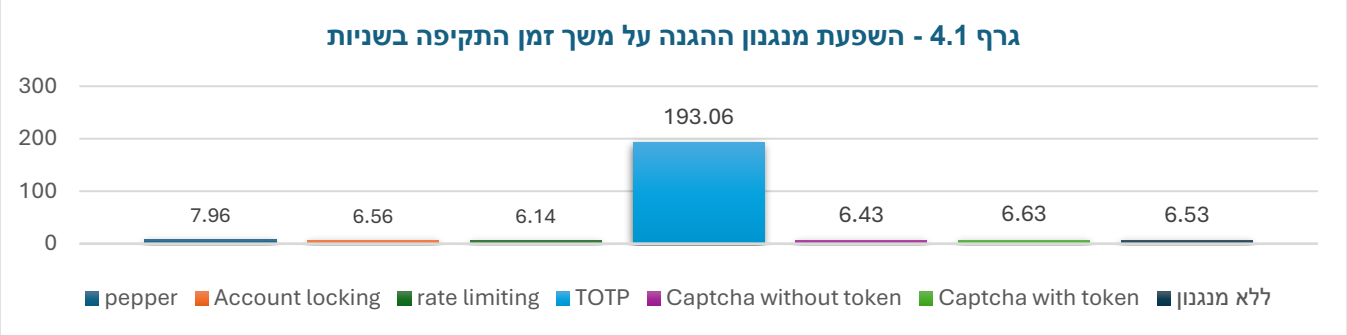


גרף 3.1 מציג את מספר ניסיונות ההחברות למשתמש בשנייה, עבור מנגנוני ההגנה השונים תוך שימוש בSHA256. מן הגרף עולה כי מנגנוני Rate limiting ו-captcha הובילו לירידה במספר הניסיונות, בעוד שמנגנוני Account locking, pepper ו-TOTP הציגו מספר ניסיונות גבוה יותר. פירוט בטבלאות 3.1, 3.2.

4. תוצאות תקיפה password spraying עם מנגנוני הגנה פרטני

מדידת הצלחת תקיפה			
מנגנון הגנה	הצלחת תקיפה	מנגנון הגנה	הצלחת התקיפה
pepper	כן	TOTP	לא
Account locking	כן	Captcha בלי טוקן	כן
rate limiting	כן	captcha עם טוקן	כן

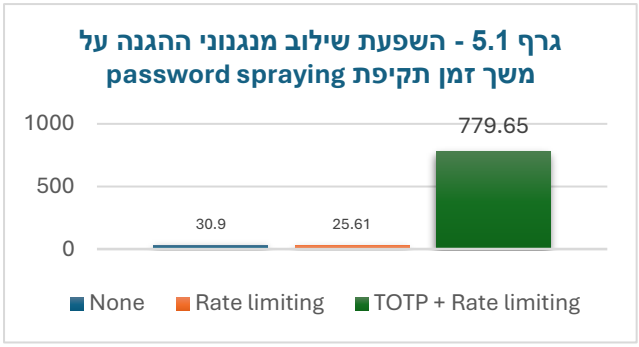
הטבלה מציגה את תוצאות התקיפה עבור מנגנוני ההגנה הפרטניים תוך שימוש ב-SHA256. ממנה עולה כי מנגנון TOTP הוביל לכישלון התקיפה, בעוד שבשאר מנגנוני ההגנה התקיפה הצליחה. נציין כי במקרה של TOTP, התקיפה הופסקה עקב הגעה למספר הניסיונות המקסימלי שהוגדר בניסוי. פירוט בטבלאות 4.1, 4.2.

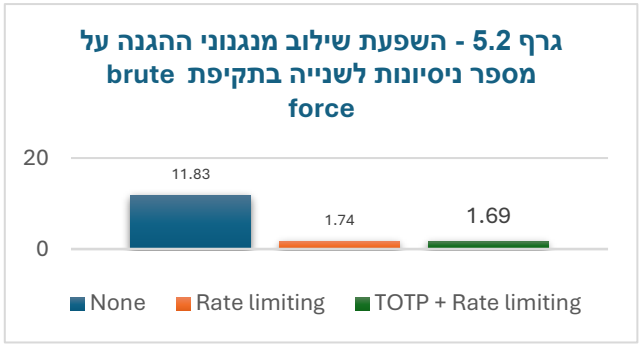


גרף 4.1 מציג את משך זמן התקיפה עבור מנגנוני ההגנה השונים. עולה שבמנגנון TOTP זמן התקיפה היה הארוך ביותר, נבע מהגעה למספר הניסיונות המקסימלי שהוגדר בניסוי, ולא ממציאת סיסמה תקפה.

5. תוצאות תקיפה עם שילובי מנגנונים נבחרים

מדידת הצלחת תקיפה					
Password spraying			**Brute force**		
הצלחת תקיפה	מנגנון הגנה	מנגנון אחסון	הצלחת תקיפה	מנגנון הגנה	מנגנון אחסון
כן	ללא מנגנון הגנה	Argon2	כן	ללא מנגנון הגנה	Argon2
כן	Rate limiting		כן	Rate limiting	
לא	TOTP + Rate limiting		לא	TOTP + Rate limiting	





הטבלה והגרפים הנתונים מציגים את השפעת שילוב מנגנוני ההגנה על שתי תקיפת שונות. בתרחיש Brute force, הוספת Rate limiting הובילה לירידה משמעותית במספר הניסיונות לשנייה, בעוד שהוספת TOTP לא שינתה את קצב התקיפה אך מנעה את הצלחתה. בתרחיש password spraying, השילוב המלא של TOTP ו-Rate limiting הוביל להארכה של זמן התקיפה ולכישלונה, השוואה לתצורות חלקיות או ללא הגנה. נציין כי בכל הניסויים בוצע שימוש באותו מנגנון אחסון Argon2. פירוט התוצאות בטבלה 5.1.

<u>ניתוח ודיון</u>

ראשית, נבחנה השפעת מנגנוני אחסון הסיסמאות על מאפייני התקיפות. תוצאות הניסויים מראות כי מנגנון SHA256 מאפשר קצב ניסיונות התחברות גבוה במיוחד, תוך צריכת משאבי מעבד וזיכרון נמוכה, מאחר וכל ניסיון אימות כולל חישוב גיבוב מהיר יחסית. מנגד, מנגנון bcrypt הפחית באופן ניכר את קצב ניסיונות ההתחברות, אך תוך שימוש אינטנסיבי במשאבי המעבד, כתוצאה מהעלות החישובית הגבוהה של כל ניסיון אימות. מנגנון Argon2 הציג קצב ניסיונות בינוני, תוך שימוש מתון במעבד ושימוש גבוה יותר בזיכרון. ממצאים אלו מדגישים את השוני בין מנגנוני הגיבוב באופן חלוקת העומס החישובי והשפעתם על קצב התקיפות.

שנית, נבחנה השפעת מנגנוני ההגנה הבודדים. מנגנון pepper, אשר משפיע על תהליך אך אינו מגביל את קצב ניסיונות ההתחברות, לא הוביל לשינוי מהותי במדדי התקיפה בתרחישי התקיפה המקוונים. מנגנון Account locking התגלה כיעיל בעצירת תקיפות Brute force לאחר מספר ניסיונות כושלים, אך יעילותו מול תקיפות Password spraying תלויה בהגדרת הסף ובדפוס ההתקפה. בנוסף, מנגנון זה עלול לפגוע בשימושיות, שכן נעילת חשבונות דורשת תהליך שחרור יזום. מנגנון Rate limiting האט באופן משמעותי את קצב ניסיונות ההתחברות בתקיפות Brute force, תוך פגיעה מוגבלת בתהליך ההתחברות התקני, מאחר וההשהיות היו זמניות. מנגד, אינו היה יעיל מול תקיפות Password spraying עקב פיזור ניסיונות ההתחברות על פני משתמשים רבים והסף הגבוה שהוגדר להפעלתו. מנגנון TOTP מנע בפועל את הצלחת התקיפות גם לאחר זיהוי סיסמה תקפה, שכן נדרש אימות נוסף שאינו תלוי סיסמה. מנגנון Captcha תרם להאטת קצב ניסיונות ההתחברות, אך לא מנע הצלחה מלאה של התקיפות בתרחיש הניסוי, תוך הוספת חיכוך לתהליך ההזדהות.

בהתייחס להבדלים בין תרחישי התקיפה, תוצאות הניסוי מדגישות את השוני המהותי הין תקיפות Brute force ו-Password spraying. בעוד שבתקיפת Brute force מנגנונים המגבילים ניסיונות עבור משתמש יחיד משפיעים באופן ישיר, תקיפת Password spraying מפזרת את ניסיונות ההתחברות על פני משתמשים רבים, ולכן מפחיתה את יעילותם של מנגנוני חסימה עבור משתמש יחיד. מנגנון TOTP, לעומת זאת, שומר על יעילותו בשני התרחישים, מאחר והוא מונע הצלחה גם כאשר סיסמה תקפה זוהתה.

כמו כן, נבחנה השפעת שילוב מנגנוני אחסון והגנה. שילוב של מנגנון עתיר משאבים עם מנגנוני הגנה המגבילים את קצב ניסיונות ההתחברות ומוסיפים שלב אימות נוסף, יוצר שכבות הגנה משלימות: האטת קצב התקיפה, הגדלת העלות החישובית לכל ניסיון, ומניעת הצלחה גם במקרה של זיהוי סיסמה תקפה. תוצאות הניסוי

מצביעות על כך ששילובים אלו משנים באופן מהותי את מאפייני התקיפה, הן מבחינת משך הזמן והן מבחינת סיכויי ההצלחה, בהשוואה לשימוש במנגנון יחיד.

לבסוף, נציין מספר מגבלות ניסוי. משך התקיפות ומספר הסיסמאות שנבדקו הוגבל, בנוסף לסף הניסיונות הכושלים על להאטה/עצירה הגבוה שהוגדר, עשויים להשפיע על אפקטיביות מנגנונים המבוססים על צבירת ניסיונות לאורך זמן.

שיקולים אתיים

במסגרת המחקר בוצעו סימולציות של Brute-force ו- Password-spraying העשויות לשמש גם בהקשרים זדונים. לפיכך, כלל הניסויים בוצעו בסביבה מבוקרת ועל שרת מקומי שנבנה על ידי מחברי העבודה בלבד. המשתמשים והסיסמאות בהם נעשה שימוש היו פיקטיביים ונוצרו לצורכי המחקר בלבד, ללא שימוש בפרטי משתמשים אמיתיים. מטרת הקוד והניסויים הייתה לימודית ומחקרית בלבד, לצורך בחינת השפעת מנגנוני אחסון ומנגנוני הגנה על עמידות מערכת האימות והעומס המוטל עליה.

במסגרת הניסוי בוצע שימוש בAI לבניית השרת, לבדיקת צריכת משאבי החומרה ולחידוד מושגים ומנגנונים שאינם היו ברורים לאחר קריאת המקורות.

מסקנות ועבודה עתידית

מסקנות

1. **שילוב המנגנונים TOTP, Argon2 ו-Rate limiting סיפק את רמת ההתמודדות הגבוהה ביותר** מבין התצורות שנמדדו כנגד התקיפות שנבחנו. שילוב זה האט באופן משמעותי את קצב התקיפות, מנע הצלחה גם לאחר זיהוי סיסמה תקפה, ופיזר את העומס החישובי בין משאבי המעבד והזיכרון.
2. **מנגנוני אחסון הסיסמאות השפיעו באופן מהותי על קצב התקיפות ועל צריכת משאבי השרת.** מנגנון SHA256 אפשר קצב ניסיונות גבוה תוך צריכת משאבים נמוכה, בעוד שמנגנוני bcrypt ו-Argon2 הגבילו את קצב התקיפות באמצעות הגדלת העלות החישובית של כל ניסיון אימות. אף ש-bcrypt הציג קצב ניסיונות נמוך יותר, הוא ריכז עומס משמעותי על המעבד. לעומתו, Argon2 השיג איזון טוב יותר בין האטת התקיפה לבין צריכת המשאבים באמצעות העברת חלק מהעומס לצריכת הזיכרון ולכן נמצא מתאים יותר למערכות אימות מקוונות.
3. **מנגנון TOTP שמר על אפקטיביות גבוה בכל תרחישי התקיפה שנבחנו.** הוספת גורם אימות שאינו תלוי בסיסמה מנעה הצלחה גם לאחר זיהוי סיסמה תקפה, והפכה את ההתקפות לבלתי אפקטיביות הן ב-Brute force והן ב-Password spraying.
4. **תקיפות Password spraying מפחיתות את יעילותם של Account locking, Rate limiting ו-Captcha.** מנגנוני חסימה והאטה ברמת משתמש היו יעילים במיוחד כנגד תקיפות Brute force, אך יעילותם פחתה בתקיפות Password spraying עקב פיזור ניסיונות ההתחברות על פני משתמשים רבים.
5. **הגדרות ספי ההפעלה של מנגנוני ההגנה משפיעות באופן ישיר על אפקטיביות ההגנה.** ספים גבוהים במנגנונים כגון Rate limiting, Account locking ו-Captcha הפחיתו את השפעתם כנגד תקיפות Password spraying ביחס לתקיפות Brute force, והדגישו את הצורך בכיול מדויק של פרמטרי ההגנה בהתאם לאופי האיום.

שיפורים אפשריים

1. הארכת משך הזמן המירבי לכל תקיפה, על מנת לבחון מנגנוני הגנה המבוססים על צבירת ניסיונות לאורך זמן.
2. שימוש במילון סיסמאות נפוצות עדכני יותר, שכן המילון בו נעשה שימוש במחקר זה מתוארך לשנת 2008 וקיימים מילונים מעודכנים המשקפים דפוסי סיסמאות עכשוויים.
3. הגדלת מספר המשתמשים בתרחישי התקיפה, לצורך בחינה מעמיקה יותר של תקיפות Password spraying בקנה מידה רחב.
4. בחינת השפעת שינוי ספי ההפעלה של מנגנוני ההגנה, כגון הפחתת מספר הניסיונות עד עצירה או האטה במנגנוני Account locking , Rate limiting ו-captcha.

<u>הרחבות עתידיות</u>

1. הרחבת הניסוי לבחינת סוגי תקיפות נוספים, כגון Brute force שאינו מבוסס מילון,SQL injection או ניסיונות DDOS .
2. הרחבת תרחישי התקיפה כך שיכללו ניסיונות פריצה גם במצב שבו מנגנון TOTP מופעל באופן מלא, לצורך בחינת עמידות המערכת מול תוקפים המנסים לעקוף או לנצל חולשות בתהליך האימות הדו שלבי

<u>מקורות</u>

1. PypI, "bcrypt 5.0.0", Sep 25,2025 , https://pypi.org/project/bcrypt/
2. D.Arias, "Hashing in Action: Understanding bcrypt", auth0 Blog, Feb 25,2021, https://auth0.com/blog/hashing-in-action-understanding-bcrypt/
3. A.Biryukov, "Argon2: the memory-hard function for password hashing and other applications", University of Luxembourg, Dec 26,2015, https://www.password-hashing.net/argon2-specs.pdf
4. PypI, "argon2-cffi 25.1.0", Jun 3,2025, https://pypi.org/project/argon2-cffi/
5. OWASP, " Authentication Cheat Sheet", https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
6. D.M'Raihi, " TOTP: Time-Based One-Time Password Algorithm", May,2011, https://datatracker.ietf.org/doc/html/rfc6238
7. PyAuto, "pyoTP - The Python One-Time Password Library", https://github.com/pyauth/pyotp
8. OWASP, "Brute Force Attack", https://owasp.org/www-community/attacks/Brute_force_attack
9. OWASP, "Password Spraying Attack", https://owasp.org/www-community/attacks/Password_Spraying_Attack

נספחים

1. טבלאות סיכום הרצות Brute force

1.1 טבלה 1.1 – השפעת מנגנוני האחסון וחוזק הסיסמאות על תקיפת Brute force

שיטת אחסון	חוזק סיסמה	משתמש	סיסמה	האם התקיפה הצליחה?	מספר ניסיון בו נעצר	זמן התקפה
sha256	weak	golom	precious	כן	235	0 שעות , 0 דקות ו- 5.52 שניות
		ron_admin	admin	כן	19818	0 שעות , 7 דקות ו- 19.05 שניות
	medium	shaked77	Rangers1	כן	27023	0 שעות , 9 דקות ו- 56.77 שניות
		elad_dev	softball24	כן	14928	0 שעות , 5 דקות ו- 53.90 שניות
	strong	Loffy	%Gear3l!&0532	לא	50000	0 שעות , 21 דקות ו- 9.69 שניות
		cyberFun	X$3kP!7mQ4r	לא	50000	0 שעות , 18 דקות ו- 56.20 שניות
bcrypt	weak	golom	precious	כן	235	0 שעות , 1 דקות ו- 10.27 שניות
		ron_admin	admin	כן	19818	1 שעות , 43 דקות ו- 2.17 שניות
	medium	shaked77	Rangers1	לא	23148	2 שעות (זמן מקסימלי)
		elad_dev	softball24	כן	14928	1 שעות , 19 דקות ו- 6.30 שניות
	strong	Loffy	%Gear3l!&0532	לא	23805	2 שעות (זמן מקסימלי)
		cyberFun	X$3kP!7mQ4r	לא	22882	2 שעות (זמן מקסימלי)
Argon2	weak	golom	precious	כן	235	0 שעות , 20 דקות ו- 19.90 שניות
		ron_admin	admin	כן	19818	0 שעות , 27 דקות ו- 21.91 שניות
	medium	shaked77	Rangers1	כן	27023	0 שעות , 39 דקות ו- 1.19 שניות
		elad_dev	softball24	כן	14928	0 שעות , 20 דקות ו- 26.47 שניות
	strong	Loffy	%Gear3l!&0532	לא	50000	1 שעות , 11 דקות ו- 2.84 שניות
		cyberFun	X$3kP!7mQ4r	לא	50000	1 שעות , 11 דקות ו- 48.31 שניות

1.2 טבלה 1.2 – השפעת מנגנוני האחסון על צריכת המעבד והשימוש בזיכרון

שיטת אחסון	חוזק סיסמה	משתמש	סיסמה	חציון צריכת המעבד	שימוש מקסימלי בזיכרון (MB)	ממוצע חציון צריכות מעבד	ממוצע ערכי שיא של שימוש הזיכרון (MB)
sha256	weak	golom	precious	21.90%	73.4	24.62%	81.4
		ron_admin	admin	25.00%	82.46		
	medium	shaked77	Rangers1	24.90%	82.73		
		elad_dev	softball24	25.00%	82.14		
	strong	Loffy	%Gear3l!&0532	24.90%	84.56		
		cyberFun	X$3kP!7mQ4r	25.00%	83.02		
bcrypt	weak	golom	precious	96.80%	76.14	94.22%	81.84
		ron_admin	admin	93.70%	82.66		
	medium	shaked77	Rangers1	93.70%	82.56		
		elad_dev	softball24	90.60%	84.29		
	strong	Loffy	%Gear3l!&0532	96.80%	82.45		
		cyberFun	X$3kP!7mQ4r	93.70%	82.94		
Argon2	weak	golom	precious	0.749	135.43	79.58%	137.05
		ron_admin	admin	0.812	137.5		
	medium	shaked77	Rangers1	0.811	137.44		
		elad_dev	softball24	0.812	137.36		
	strong	Loffy	%Gear3l!&0532	0.781	137.16		
		cyberFun	X$3kP!7mQ4r	0.81	137.4		

1.3 טבלה 1.3 – ממוצע זמני התגובה לפי מנגנון אחסון

שיטת אחסון	חוזק סיסמה	משתמש	סיסמה	ממוצע latency ms	ממוצע זמני התגובה לפי מנגנון אחסון
sha256	weak	golom	precious	1.55	1.55
		ron_admin	admin	1.48	
	medium	shaked77	Rangers1	1.47	
		elad_dev	softball24	1.61	
	strong	Loffy	%Gear3l!&0532	1.58	
		cyberFun	X$3kP!7mQ4r	1.63	
bcrypt	weak	golom	precious	283.77	292.35
		ron_admin	admin	294.49	
	medium	shaked77	Rangers1	293.1	
		elad_dev	softball24	300.76	
	strong	Loffy	%Gear3l!&0532	284.58	
		cyberFun	X$3kP!7mQ4r	297.4	
Argon2	weak	golom	precious	64.63	63.31
		ron_admin	admin	61	
	medium	shaked77	Rangers1	64.6	
		elad_dev	softball24	61.64	
	strong	Loffy	%Gear3l!&0532	64.03	
		cyberFun	X$3kP!7mQ4r	63.95	

2. **<u>טבלאות סיכום הרצות password spraying</u>**

2.1 טבלה 2.1 – סיכום תוצאות תקיפה password spraying

שיטת אחסון	האם נמצאה סיסמה	לאיזה משתמש	הסיסמה למשתמש	מספר ניסיון בו נעצר	זמן חיפוש	מספר ניסיונות לשנייה	Latency ms
sha256	כן	daniel01	12345678	243	0 שעות , 0 דקות ו- 6.53 שניות	37.23	6.7
bcrypt	כן	daniel01	12345678	243	0 שעות , 1 דקות ו- 35.86 שניות	2.54	380.2
Argon2	כן	daniel01	12345678	243	0 שעות , 0 דקות ו- 30.90 שניות	7.86	110.3

2.2 טבלה 2.2 – השפעה על צריכת המעבד והשימוש בזיכרון

שיטת אחסון	האם נמצאה סיסמה	לאיזה משתמש	הסיסמה למשתמש	חציון צריכת המעבד	שימוש מקסימלי בזיכרון (MB)
sha256	כן	daniel01	12345678	34.40%	77.86
bcrypt	כן	daniel01	12345678	93.50%	71.27
Argon2	כן	daniel01	12345678	71.80%	135.38

3. טבלאות הרצות – מנגנוני הגנה – Brute force

3.1 טבלה 3.1 – סיכום תוצאות תקיפה Brute force עם מנגנוני הגנה

מנגנון הגנה	הגדרות מנגנון	שיטת אחסון	המשתמש הנתקף	האם התקיפה הצליחה	מספר ניסיון בו נעצר	זמן תקיפה	מספר ניסיונות לשנייה
pepper	14320970	sha256	golom	כן	235	0 שעות , 0 דקות ו- 5.56 שניות	42.29
Account locking	max_attempts = 10	sha256	golom	לא	10	0 שעות , 0 דקות ו- 0.21 שניות	48.19
rate limiting	max_attempts = 10. delay seconds = 5	sha256	golom	כן	235	0 שעות , 2 דקות ו- 1.99 שניות	1.93
TOTP	____	sha256	golom	לא	235	0 שעות , 0 דקות ו- 6.04 שניות	38.92
captcha בלי טוקן	failed attempts = 10. delay seconds = 5	sha256	golom	כן	235	0 שעות , 3 דקות ו- 58.66 שניות	0.98
captcha עם טוקן	failed attempts = 10. delay seconds = 1	sha256	golom	כן	235	0 שעות , 0 דקות ו- 33.66 שניות	6.98
rate +TOTP limiting	.10 = max_attempts delay seconds = 5	Argon2	golom	לא	235	0 שעות , 2 דקות ו- 14.98 שניות	1.74
rate limiting	failed attempts = 10. delay seconds = 5	Argon2	golom	כן	235	0 שעות , 2 דקות ו- 19.26 שניות	1.69

3.2 טבלה 3.2 – השפעת מנגנוני ההגנה על צריכת המעבד והשימוש בזיכרון בBrute force

מנגנון הגנה	הגדרות מנגנון	שיטת אחסון	המשתמש הנתקף	חציון צריכת המעבד	שימוש מקסימלי בזיכרון (MB)
pepper	14320970	sha256	golom	25.00%	71.68
Account locking	max_attempts = 10	sha256	golom	10.95%	71.81
rate limiting	max_attempts = 10. delay seconds = 5	sha256	golom	0.00%	74.38
TOTP	____	sha256	golom	32.75%	71.95
captcha בלי טוקן	failed attempts = 10. delay seconds = 5	sha256	golom	0.00%	78.53
captcha עם טוקן	failed attempts = 10. delay seconds = 1	sha256	golom	3.10%	71.75
rate +TOTP limiting	.10 = max_attempts delay seconds = 5	Argon2	golom	0.00%	137.52
rate limiting	failed attempts = 10. delay seconds = 5	Argon2	golom	0.00%	138.2

4. טבלאות הרצה מנגנוני הגנה Password spraying

4.1_טבלה 4.1 - סיכום תוצאות תקיפה Password spraying עם מנגנוני הגנה

מנגנון הגנה	הגדרות מנגנון	שיטת אחסון	האם התקיפה הצליחה?	משתמש שנמצא	סיסמה	מספר ניסיון בו נעצר	זמן תקיפה	מספר ניסיונות לשנייה
pepper	14320970	sha256	כן	daniel101	12345678	243	0 שעות , 0 דקות ו- 7.96 שניות	30.51
Account locking	max_attempts = 10	sha256	כן	daniel101	12345678	243	0 שעות , 0 דקות ו- 6.56 שניות	37.03
rate limiting	max_attempts = 10. delay seconds = 5	sha256	כן	daniel101	12345678	243	0 שעות , 0 דקות ו- 6.14 שניות	39.59
TOTP	____	sha256	לא	____	_____	4501	0 שעות , 3 דקות ו- 13.06 שניות	23.31
captcha בלי טוקן	failed attempts = 10. delay seconds = 5	sha256	כן	daniel101	12345678	243	0 שעות , 0 דקות ו- 6.43 שניות	37.81
captcha עם טוקן	failed attempts = 10. delay seconds = 1	sha256	כן	daniel101	12345678	243	0 שעות , 0 דקות ו- 6.63 שניות	36.67
rate +TOTP limiting	.10 = max_attempts delay seconds = 5	Argon2	לא	____	_____	4501	0 שעות , 12 דקות ו- 59.65 שניות	5.77
rate limiting	failed attempts = 10. delay seconds = 5	Argon2	כן	golom	precious	243	0 שעות , 0 דקות ו- 25.61 שניות	9.49

4.2 טבלה 3.2 – השפעת מנגנוני ההגנה על צריכת המעבד והשימוש בזיכרון בPassword spraying

מנגנון הגנה	הגדרות מנגנון	שיטת אחסון	חציון צריכת המעבד	שימוש מקסימלי בזיכרון (MB)
pepper	14320970	sha256	37.20%	71.67
Account locking	max_attempts = 10	sha256	34.40%	71.45
rate limiting	max_attempts = 10. delay seconds = 5	sha256	31.20%	81.18
TOTP	____	sha256	25.00%	82.43
captcha בלי טוקן	failed attempts = 10. delay seconds = 5	sha256	35.90%	74.76
captcha עם טוקן	failed attempts = 10. delay seconds = 1	sha256	34.40%	71.63
rate +TOTP limiting	.10 = max_attempts delay seconds = 5	Argon2	72.90%	140.99
rate limiting	failed attempts = 10. delay seconds = 5	Argon2	84.20%	135.91

5. פלטי הרצות Brute force

5.1 הרצה עם sha256

5.11 golom

```
235) Trying password: precious
Password found: 'precious', for user: 'golom', on try number: 235
Status: 200
Total attempts: 235
Run time: 0 Hours, 0 Minutes and 5.52 seconds
Attempts per second: 42.56
Average CPU usage: 19.20%
Median CPU usage: 21.90%
Peak RSS Memory usage: 73.40 MB
Resource samples collected: 13
```

5.12 ron_admin

```
19818) Trying password: admin
Password found: 'admin', for user: 'ron_admin', on try number: 19818
Status: 200
Total attempts: 19818
Run time: 0 Hours, 7 Minutes and 19.05 seconds
Attempts per second: 45.14
Average CPU usage: 23.41%
Median CPU usage: 25.00%
Peak RSS Memory usage: 82.46 MB
Resource samples collected: 878
```

5.13 elad_dev

```
14928) Trying password: softball24
Password found: 'softball24', for user: 'elad_dev', on try number: 14928
Status: 200
Total attempts: 14928
Run time: 0 Hours, 5 Minutes and 53.90 seconds
Attempts per second: 42.18
Average CPU usage: 23.33%
Median CPU usage: 25.00%
Peak RSS Memory usage: 82.14 MB
Resource samples collected: 708
```

5.14 Shaked77

```
27023) Trying password: Rangers1
Password found: 'Rangers1', for user: 'shaked77', on try number: 27023
Status: 200
Total attempts: 27023
Run time: 0 Hours, 9 Minutes and 56.77 seconds
Attempts per second: 45.28
Average CPU usage: 23.63%
Median CPU usage: 24.90%
Peak RSS Memory usage: 82.73 MB
Resource samples collected: 1193
```

```
50000) Trying password: alex2004
Reached maximum attempts for brute-force.
Status: 200
Total attempts: 50000
Run time: 0 Hours, 21 Minutes and 9.69 seconds
Attempts per second: 39.38
Average CPU usage: 21.07%
Median CPU usage: 24.90%
Peak RSS Memory usage: 84.56 MB
Resource samples collected: 2537
```

<u>הרצה עם bcrypt</u>

golom 5.16

```
Password found: 'precious', for user: 'golom', on try number: 235
Status: 200
Total attempts: 235
Run time: 0 Hours, 1 Minutes and 10.27 seconds
Attempts per second: 3.34
Average CPU usage: 92.64%
Median CPU usage: 96.80%
Peak RSS Memory usage: 76.14 MB
Resource samples collected: 142
```

ron_admin 5.17

```
19818) Trying password: admin
Password found: 'admin', for user: 'ron_admin', on try number: 19818
Status: 200
Total attempts: 19818
Run time: 1 Hours, 43 Minutes and 2.17 seconds
Attempts per second: 3.21
Average CPU usage: 90.56%
Median CPU usage: 93.70%
Peak RSS Memory usage: 82.66 MB
Resource samples collected: 12350
```

elad_dev 5.18

```
14928) Trying password: softball24
Password found: 'softball24', for user: 'elad_dev', on try number: 14928
Status: 200
Total attempts: 14928
Run time: 1 Hours, 19 Minutes and 6.30 seconds
Attempts per second: 3.15
Average CPU usage: 88.75%
Median CPU usage: 90.60%
Peak RSS Memory usage: 84.29 MB
Resource samples collected: 9480
```

Shaked77 5.19

```
23148) Trying password: 121204
Time limit reached for brute-force attack.
Status: 200
Total attempts: 23148
Run time: 2 Hours, 0 Minutes and 0.13 seconds
Attempts per second: 3.21
Average CPU usage: 90.60%
Median CPU usage: 93.70%
Peak RSS Memory usage: 82.56 MB
Resource samples collected: 14383
```

Loffy 5.110

```
23805) Trying password: 246824
Time limit reached for brute-force attack.
Status: 200
Total attempts: 23805
Run time: 2 Hours, 0 Minutes and 0.10 seconds
Attempts per second: 3.31
Average CPU usage: 93.03%
Median CPU usage: 96.80%
Peak RSS Memory usage: 82.45 MB
Resource samples collected: 14381
```

CyberFun 5.111

```
22882) Trying password: r2d2c3po
Time limit reached for brute-force attack.
Status: 200
Total attempts: 22882
Run time: 2 Hours, 0 Minutes and 0.17 seconds
Attempts per second: 3.18
Average CPU usage: 90.35%
Median CPU usage: 93.70%
Peak RSS Memory usage: 82.94 MB
Resource samples collected: 14383
```

5.2 הרצה עם argon2

golom 5.21

```
235) Trying password: precious
Password found: 'precious', for user: 'golom', on try number: 235
Status: 200
Total attempts: 235
Run time: 0 Hours, 0 Minutes and 19.90 seconds
Attempts per second: 11.81
Average CPU usage: 69.14%
Median CPU usage: 74.90%
Peak RSS Memory usage: 135.43 MB
Resource samples collected: 41
```

ron_admin 5.22

```
19818) Trying password: admin
Password found: 'admin', for user: 'ron_admin', on try number: 19818
Status: 200
Total attempts: 19818
Run time: 0 Hours, 27 Minutes and 21.91 seconds
Attempts per second: 12.07
Average CPU usage: 74.11%
Median CPU usage: 81.20%
Peak RSS Memory usage: 137.50 MB
Resource samples collected: 3281
```

elad_dev 5.23

```
14928) Trying password: softball24
Password found: 'softball24', for user: 'elad_dev', on try number: 14928
Status: 200
Total attempts: 14928
Run time: 0 Hours, 20 Minutes and 26.47 seconds
Attempts per second: 12.17
Average CPU usage: 74.00%
Median CPU usage: 81.20%
Peak RSS Memory usage: 137.36 MB
Resource samples collected: 2451
```

Shaked77 5.24

```
27023) Trying password: Rangers1
Password found: 'Rangers1', for user: 'shaked77', on try number: 27023
Status: 200
Total attempts: 27023
Run time: 0 Hours, 39 Minutes and 1.19 seconds
Attempts per second: 11.54
Average CPU usage: 73.44%
Median CPU usage: 81.10%
Peak RSS Memory usage: 137.44 MB
Resource samples collected: 4678
```

Loffy 5.25

```
50000) Trying password: alex2004
Reached maximum attempts for brute-force.
Status: 200
Total attempts: 50000
Run time: 1 Hours, 11 Minutes and 2.84 seconds
Attempts per second: 11.73
Average CPU usage: 72.45%
Median CPU usage: 78.10%
Peak RSS Memory usage: 137.16 MB
Resource samples collected: 8516
```

cyberFun 5.26

```
50000) Trying password: alex2004
Reached maximum attempts for brute-force.
Status: 200
Total attempts: 50000
Run time: 1 Hours, 11 Minutes and 48.31 seconds
Attempts per second: 11.61
Average CPU usage: 73.34%
Median CPU usage: 81.00%
Peak RSS Memory usage: 137.40 MB
Resource samples collected: 8608
```

6. הרצת password spraying

6.1 הרצה עם sha256

```
243) Trying password: 12345678 for user: daniel01
Password found: '12345678', for user: 'daniel01', on try number: 243
Status: 200
Total attempts: 243
Run time: 0 Hours, 0 Minutes and 6.53 seconds
Attempts per second: 37.23
Average CPU usage: 26.43%
Median CPU usage: 34.40%
Peak RSS Memory usage: 77.86 MB
Resource samples collected: 15
```

6.2 הרצה עם bcrypt

```
243) Trying password: 12345678 for user: daniel01
Password found: '12345678', for user: 'daniel01', on try number: 243
Status: 200
Total attempts: 243
Run time: 0 Hours, 1 Minutes and 35.86 seconds
Attempts per second: 2.54
Average CPU usage: 89.81%
Median CPU usage: 93.50%
Peak RSS Memory usage: 71.27 MB
Resource samples collected: 193
```

6.3 הרצה עם argon 2

```
243) Trying password: 12345678 for user: daniel01
Password found: '12345678', for user: 'daniel01', on try number: 243
Status: 200
Total attempts: 243
Run time: 0 Hours, 0 Minutes and 30.90 seconds
Attempts per second: 7.86
Average CPU usage: 66.61%
Median CPU usage: 71.80%
Peak RSS Memory usage: 135.38 MB
Resource samples collected: 63
```

7. פלטי הרצות – ניסויים עם מנגנוני הגנה

7.1 שימוש בpepper

```
235) Trying password: precious
Password found: 'precious', for user: 'golom', on try number: 235
Status: 200
Total attempts: 235
Run time: 0 Hours, 0 Minutes and 5.56 seconds
Attempts per second: 42.29
Average CPU usage: 25.47%
Median CPU usage: 25.00%
Peak RSS Memory usage: 71.68 MB
Resource samples collected: 13
```

7.2 שימוש בTOTP

```
235) Trying password: precious
TOTP required for user 'golom' after 235 attempts. Stopping brute-force.
Status: 200
Total attempts: 235
Run time: 0 Hours, 0 Minutes and 6.04 seconds
Attempts per second: 38.92
Average CPU usage: 26.76%
Median CPU usage: 32.75%
Peak RSS Memory usage: 71.95 MB
Resource samples collected: 14
```

7.3 Account locking

```
10) Trying password: abc123
golom Account locked out after 10 attempts.
Status: 500
Total attempts: 10
Run time: 0 Hours, 0 Minutes and 0.21 seconds
Attempts per second: 48.19
Average CPU usage: 10.95%
Median CPU usage: 10.95%
Peak RSS Memory usage: 71.81 MB
Resource samples collected: 2
```

7.4 Rate limiting

```
235) Trying password: precious
Password found: 'precious', for user: 'golom', on try number: 235
Status: 200
Total attempts: 235
Run time: 0 Hours, 2 Minutes and 1.99 seconds
Attempts per second: 1.93
Average CPU usage: 1.87%
Median CPU usage: 0.00%
Peak RSS Memory usage: 74.38 MB
Resource samples collected: 245
```

7.5 Captcha שאין לתוקף את הטוקן

```
235) Trying password: precious
Password found: 'precious', for user: 'golom', on try number: 235
Status: 200
Total attempts: 235
Run time: 0 Hours, 3 Minutes and 58.66 seconds
Attempts per second: 0.98
Average CPU usage: 0.88%
Median CPU usage: 0.00%
Peak RSS Memory usage: 78.53 MB
Resource samples collected: 478
```

7.6 Captcha כשיש לתוקף את הטוקן

```
235) Trying password: precious
Password found: 'precious', for user: 'golom', on try number: 235
Status: 200
Total attempts: 235
Run time: 0 Hours, 0 Minutes and 33.66 seconds
Attempts per second: 6.98
Average CPU usage: 6.15%
Median CPU usage: 3.10%
Peak RSS Memory usage: 71.75 MB
Resource samples collected: 69
```

8. פלטי הרצות ניסויים עם מנגנוני הגנה – password spraying

8.1 Peppr

```
243) Trying password: 12345678 for user: daniel01
Password found: '12345678', for user: 'daniel01', on try number: 243
Status: 200
Total attempts: 243
Run time: 0 Hours, 0 Minutes and 7.96 seconds
Attempts per second: 30.51
Average CPU usage: 30.29%
Median CPU usage: 37.20%
Peak RSS Memory usage: 71.67 MB
Resource samples collected: 17
```

TOTP 8.2

```
4500) Trying password: patricia for user: tal_root
Reached maximum number of attempts for password spraying.
Status: 200
Total attempts: 4501
Run time: 0 Hours, 3 Minutes and 13.06 seconds
Attempts per second: 23.31
Average CPU usage: 23.58%
Median CPU usage: 25.00%
Peak RSS Memory usage: 82.43 MB
Resource samples collected: 387
```

Account locking 8.3

```
243) Trying password: 12345678 for user: daniel01
Password found: '12345678', for user: 'daniel01', on try number: 243
Status: 200
Total attempts: 243
Run time: 0 Hours, 0 Minutes and 6.56 seconds
Attempts per second: 37.03
Average CPU usage: 30.81%
Median CPU usage: 34.40%
Peak RSS Memory usage: 71.45 MB
Resource samples collected: 15
```

Rate limiting 8.4

```
243) Trying password: 12345678 for user: daniel01
Password found: '12345678', for user: 'daniel01', on try number: 243
Status: 200
Total attempts: 243
Run time: 0 Hours, 0 Minutes and 6.14 seconds
Attempts per second: 39.59
Average CPU usage: 30.11%
Median CPU usage: 31.20%
Peak RSS Memory usage: 81.18 MB
Resource samples collected: 14
```

Captcha בלי טוקן 8.5

```
243) Trying password: 12345678 for user: daniel01
Password found: '12345678', for user: 'daniel01', on try number: 243
Status: 200
Total attempts: 243
Run time: 0 Hours, 0 Minutes and 6.43 seconds
Attempts per second: 37.81
Average CPU usage: 33.62%
Median CPU usage: 35.90%
Peak RSS Memory usage: 74.76 MB
Resource samples collected: 14
```

8.6 Captcha עם טוקן

```
243) Trying password: 12345678 for user: daniel01
Password found: '12345678', for user: 'daniel01', on try number: 243
Status: 200
Total attempts: 243
Run time: 0 Hours, 0 Minutes and 6.63 seconds
Attempts per second: 36.67
Average CPU usage: 29.97%
Median CPU usage: 34.40%
Peak RSS Memory usage: 71.63 MB
Resource samples collected: 15
```

9. שילובי מנגנונים

9.1 Rate limiting + Argon2 – Brute force

```
235) Trying password: precious
Password found: 'precious', for user: 'golom', on try number: 235
Status: 200
Total attempts: 235
Run time: 0 Hours, 2 Minutes and 19.26 seconds
Attempts per second: 1.69
Average CPU usage: 13.45%
Median CPU usage: 0.00%
Peak RSS Memory usage: 138.20 MB
Resource samples collected: 279
```

9.2 TOTP + rate limiting + Argon2 – Brute force

```
235) Trying password: precious
TOTP required for user 'golom' after 235 attempts. Stopping brute-force.
Status: 200
Total attempts: 235
Run time: 0 Hours, 2 Minutes and 14.98 seconds
Attempts per second: 1.74
Average CPU usage: 10.54%
Median CPU usage: 0.00%
Peak RSS Memory usage: 137.52 MB
Resource samples collected: 271
```

9.3 Rate limiting + Argon2 – password spraying

```
243) Trying password: 12345678 for user: daniel01
Password found: '12345678', for user: 'daniel01', on try number: 243
Status: 200
Total attempts: 243
Run time: 0 Hours, 0 Minutes and 25.61 seconds
Attempts per second: 9.49
Average CPU usage: 76.57%
Median CPU usage: 84.20%
Peak RSS Memory usage: 135.91 MB
Resource samples collected: 53
```

TOTP + rate limiting + Argon2 – password spraying 9.4

```
4500) Trying password: patricia for user: tal_root
Reached maximum number of attempts for password spraying.
Status: 200
Total attempts: 4501
Run time: 0 Hours, 12 Minutes and 59.65 seconds
Attempts per second: 5.77
Average CPU usage: 57.19%
Median CPU usage: 72.90%
Peak RSS Memory usage: 140.99 MB
Resource samples collected: 1557
```